UNIVERSIDAD PRIVADA DE TACNA · ESCUELA DE INGENIERÍA DE SISTEMAS

Diseño de una capa de publicación segura y de alta disponibilidad para la Universidad

Con OPNsense, Nginx, ModSecurity + OWASP CRS y keepalived



Integrantes

Calizaya Ladera, Andy Michael
Camac Melendez, Cesar Nikolas
Castillo Mamani, Diego Fernando
Colque Ponce, Sergio Alberto
Ancco Suaña, Bruno Enrique

Curso: Seguridad de TI

Docente: Dr. Renzo Alberto Taco Coayla

Tacna – Perú · 2026-II

El problema: aplicaciones sin filtro

25 065

solicitudes anómalas con respuesta HTTP sin WAF: el 100 % no fue filtrado

61 065

solicitudes del conjunto HTTP CSIC 2010: 36 000 legítimas y 25 065 anómalas

8 400

usuarios de la Universidad X (contexto hipotético; no se despliega a esa escala)

Situación de partida

- Cada aplicación se publica sin política WAF común
- Sin segmentación formal de redes
- Sin redundancia de publicación
- Moodle y sistemas reales quedan fuera del alcance

Pregunta del proyecto

¿Cómo inspeccionar solicitudes, conservar el acceso legítimo y recuperar el servicio ante la falla de un proxy, con criterios medibles?

Objetivos

Objetivo general Diseñar un laboratorio de 4 VM que integre OPNsense, Nginx + ModSecurity + OWASP CRS, VPN con MFA y keepalived, con pruebas de protección, recuperación y conmutación ≤ 5 s sin desactivar el WAF.

OE1 Fundamentar el problema con ≥ 40 fuentes citadas

OE2 Especificar 6 RF y 9 RNF medibles, cada uno con su prueba

OE3 Diseñar arquitectura, infraestructura y red (4 diagramas)

OE4 Definir seguridad y recuperación: 9 riesgos, RPO y RTO

OE5 Planificar operación, implementación (4 semanas) y costos

OE6 Diseñar la validación: 14 pruebas reproducibles

Requerimientos y umbrales de aceptación

6 requerimientos funcionales

RF-01	Publicar 1 aplicación por HTTPS (TLS 1.2/1.3); backend inaccesible
RF-02	Inspeccionar con ModSecurity + CRS en modo bloqueo
RF-03	Migrar la VIP si cae el nodo o Nginx
RF-04	Correlacionar cada bloqueo con su registro
RF-05	Límites de tasa: exceso recibe 429
RF-06	Administrar solo por VPN con MFA y RBAC

≤ 5 s

conmutación por repetición (RNF-02)

< 50 ms

diferencia de latencia p95 con 50 usuarios (RNF-03)

≥ 90 %

detección en PL1 con falsos positivos ≤ 2 % (RNF-04)

≤ 1 %

solicitudes legítimas fallidas a 50 usuarios (RNF-05)

Arquitectura lógica de protección web

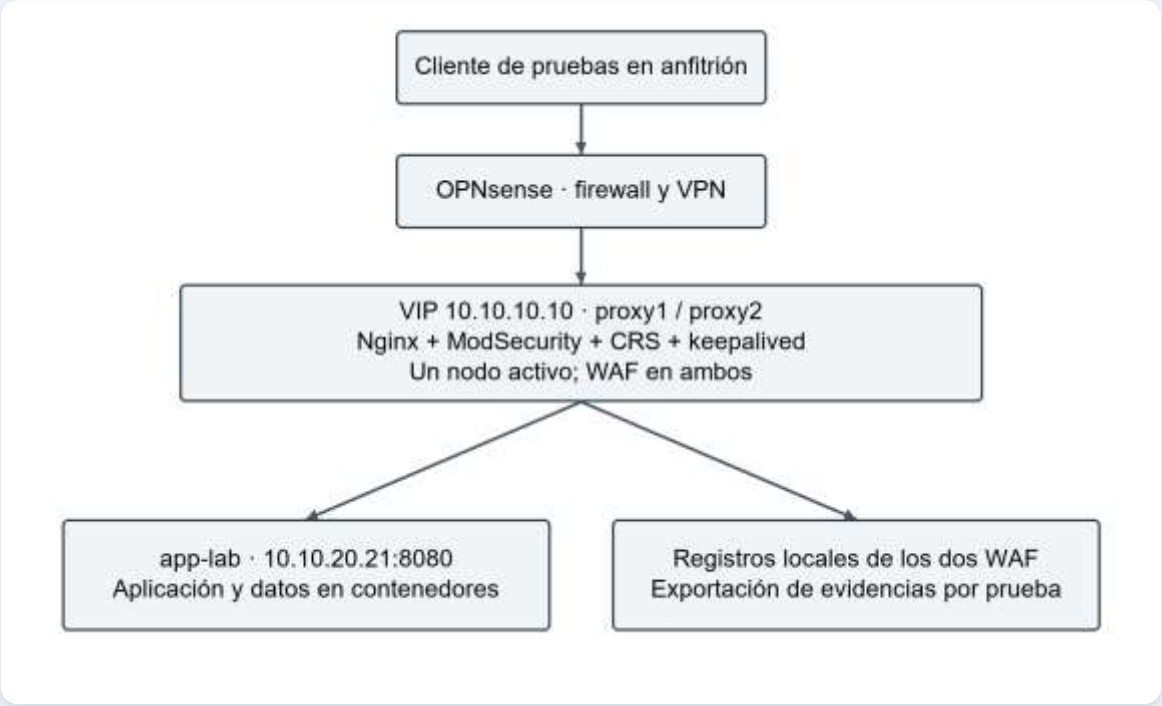


Figura 1 · Arquitectura lógica de protección web

1. OPNsense permite HTTPS hacia la VIP 10.10.10.10
2. Nginx termina TLS y entrega la solicitud a ModSecurity + CRS
3. Las solicitudes aceptadas llegan al puerto 8080 de app-lab
4. Ambos proxies mantienen el WAF activo; uno atiende la VIP

Infraestructura: cuatro VM en un equipo

4 VM

firewall, proxies y app-lab

10 vCPU

asignadas en total

14 GB

de RAM para las VM

160 GB

de disco asignado

Límite: equipo físico, firewall y aplicación son puntos únicos de falla; se demuestra la disponibilidad de la capa proxy.

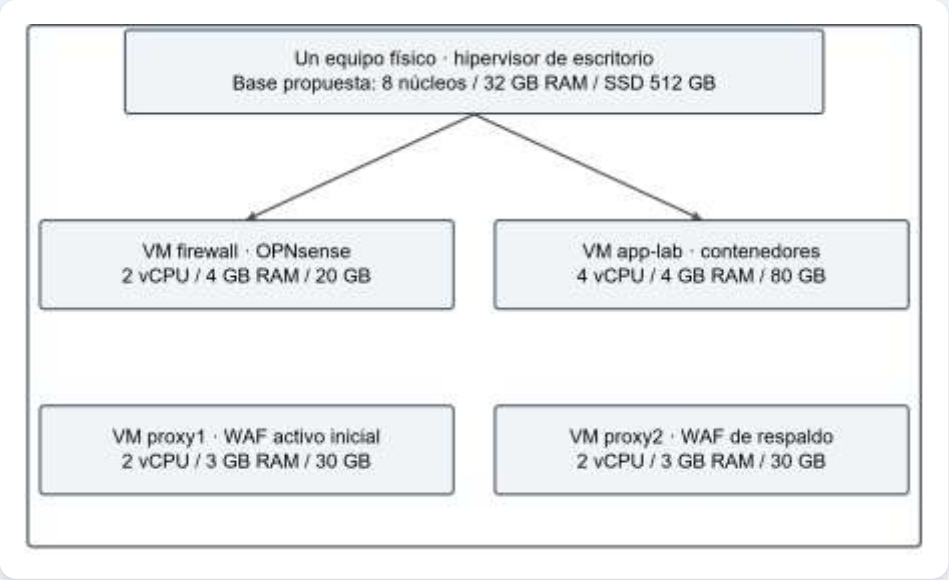


Figura 2 · Despliegue en un equipo físico

Diseño de red y segmentación

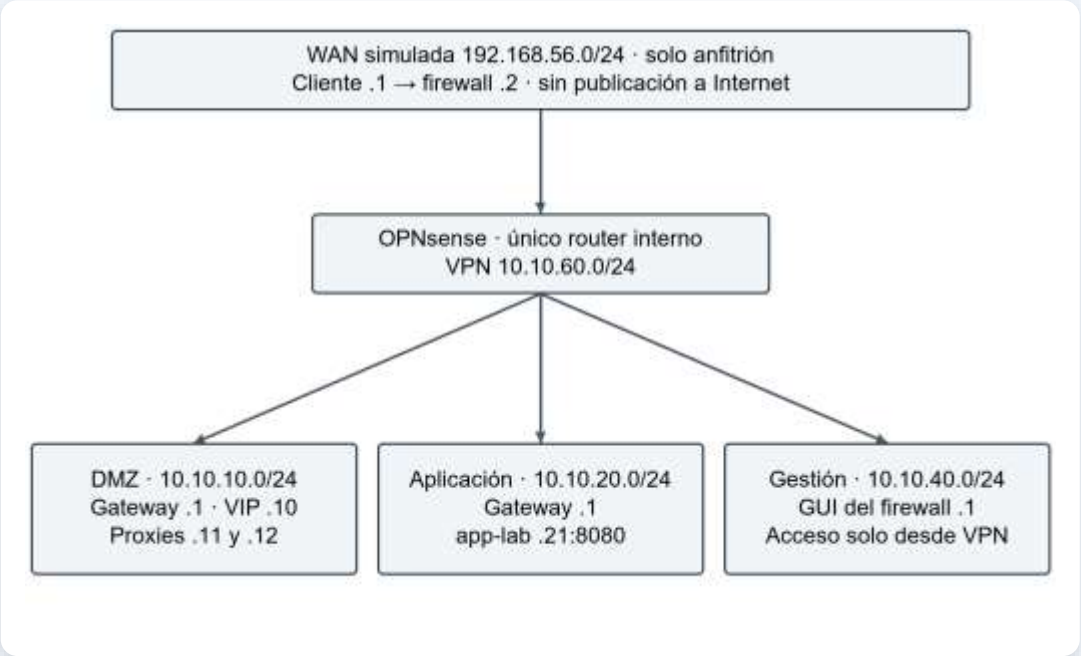


Figura 3 · Topología de redes virtuales aisladas

Zona	VLAN	Subred
DMZ	10	10.10.10.0/24
Aplicaciones	20	10.10.20.0/24
Gestión	40	10.10.40.0/24
VPN	túnel	10.10.60.0/24

- OPNsense es el único router interno
- Todo flujo no listado se deniega (R10)
- Puerto 8080 de app-lab solo para .11 y .12

Seguridad: barreras, auditoría y recuperación

9 riesgos valorados (ISO/IEC 27005); R1 SQLi/XSS baja de 20 a 10

VPN OpenVPN con certificado + TOTP y permisos por rol

PL1 CRS en observación y luego en bloqueo, con excepciones mínimas

2 h RTO (RPO 24 h) con copias cifradas y restauración aislada

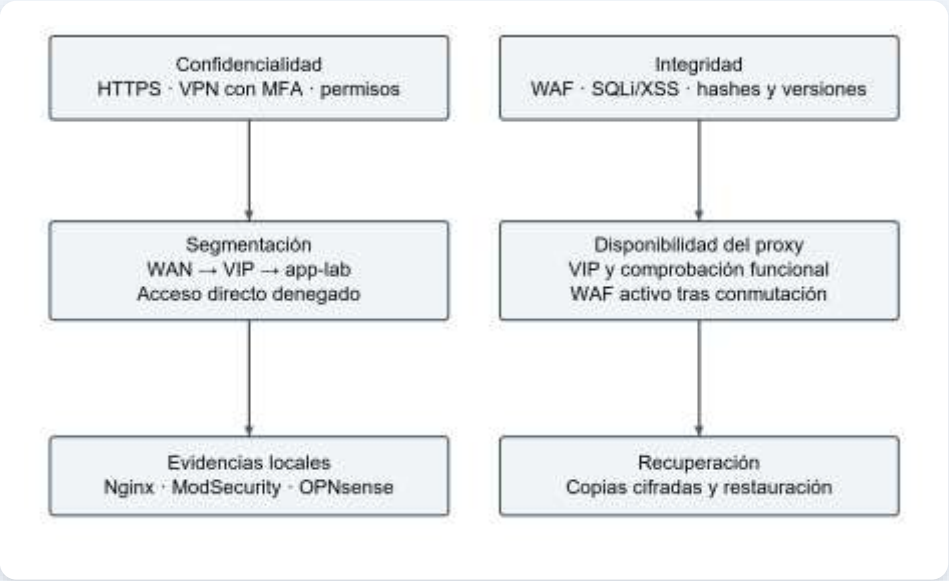


Figura 4 · Controles de seguridad y recuperación

Plan de implementación: 4 semanas

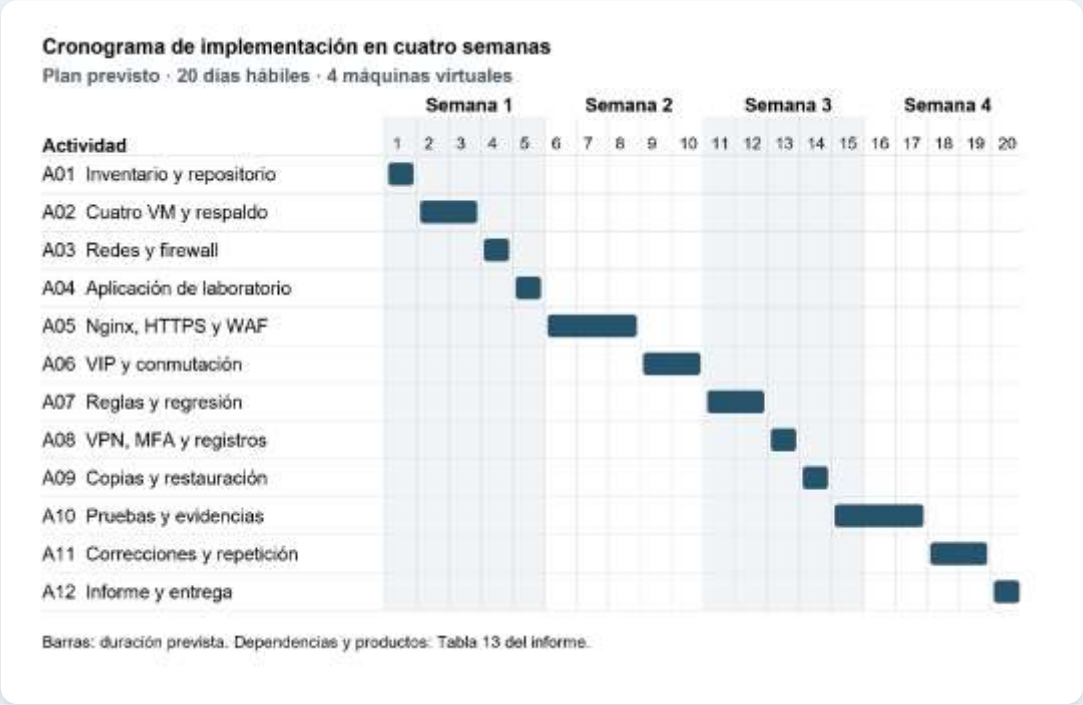


Figura 5 · Diagrama de Gantt de implementación

S1 — Base
VM, redes, firewall y aplicación

S2 — WAF y HA
Nginx, CRS, VIP y conmutación

S3 — Ajustes
PL1/PL2, VPN con MFA, restauración

S4 — Cierre
Pruebas, correcciones e informe

Plan de pruebas y costos

14 casos de prueba

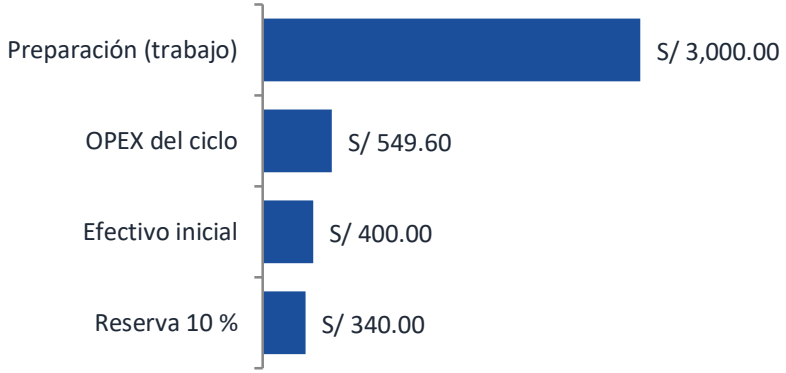
4 **Protección web**
PT-01, 02, 03 y 08: HTTPS, SQLi/XSS, límites

4 **Continuidad**
PT-04, 04b, 05 y 06: conmutación y carga

2 **Auditoría y cambios**
PT-07 y 09: registros y recarga de reglas

4 **Acceso y recuperación**
PT-10 a 13: VPN, restauración, flujos, incidente

S/ 4 289,60 TCO del ciclo



Efectivo incremental estimado: S/ 489,60. Importes supuestos de planificación con equipo reutilizado.

Conclusiones

1. **Diseño integrado**
   Segmentación, WAF redundante, VPN con MFA y recuperación en 4 VM.

2. **Prueba de concepto**
   CRS bloquea la SQLi (403) y keepalived conmuta en ~ 1 s con el WAF activo.

3. **Límites claros**
   Equipo, firewall y aplicación siguen siendo puntos únicos; la validación final es de la Unidad III.

Repositorio y evidencias

GitHub

Google Drive

Gracias · ¿Preguntas?

Evidencia 1: línea base sin WAF

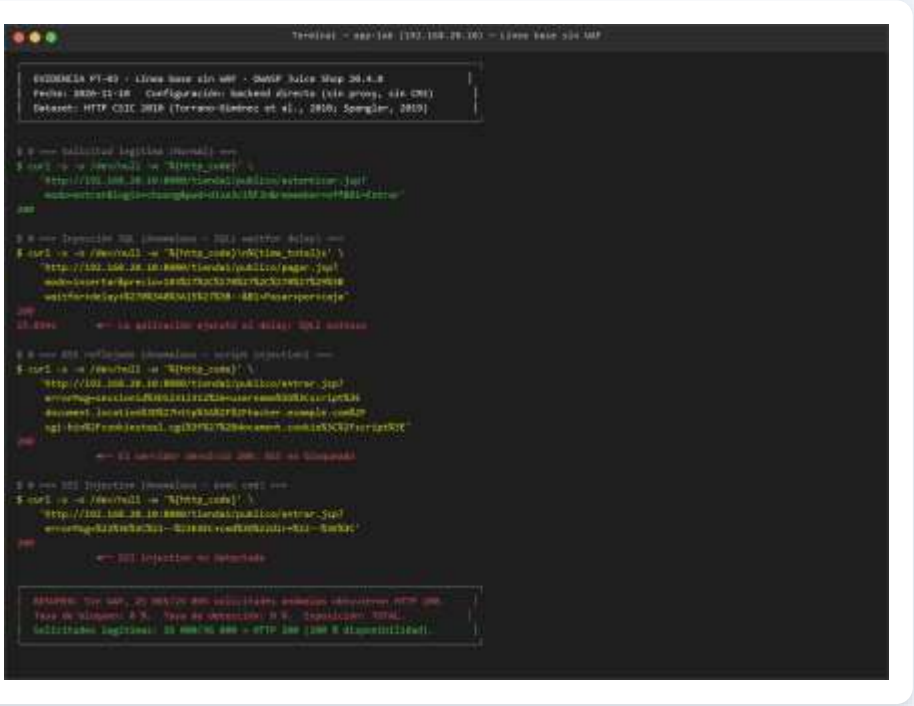


Figura 6 · Línea base sin WAF (CSIC 2010)

200

HTTP en SQLi, XSS y SSI: ningún bloqueo

15,0 s

la SQLi con waitfor delay se ejecutó en la aplicación

0 %

tasa de bloqueo de 25 065 solicitudes anómalas

Evidencia 2: bloqueo CRS con auditoría

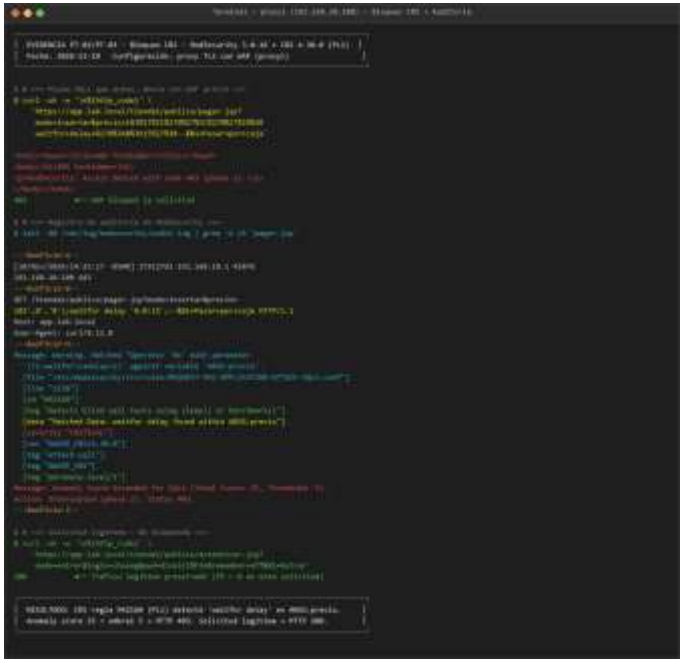


Figura 7 · Bloqueo por CRS y registro de ModSecurity

403

la misma SQLi queda bloqueada por el WAF

Registro de auditoría

- Regla 942160 · OWASP CRS 4.30.0 · PL1
- Severidad CRITICAL · detectó «waitfor delay»
- Anomaly score 25 > umbral 5
- Solicitud legítima posterior: HTTP 200

Evidencia 3: conmutación con keepalived

~ 1 s

conmutación completa (umbral: 5 s)

- La VIP migra de proxy1 a proxy2 con ARP gratuito
- 3/3 repeticiones exitosas; máximo 1,8 s
- El WAF sigue activo: la misma SQLi recibe 403

Apagado ordenado; el corte abrupto se mide en PT-04.

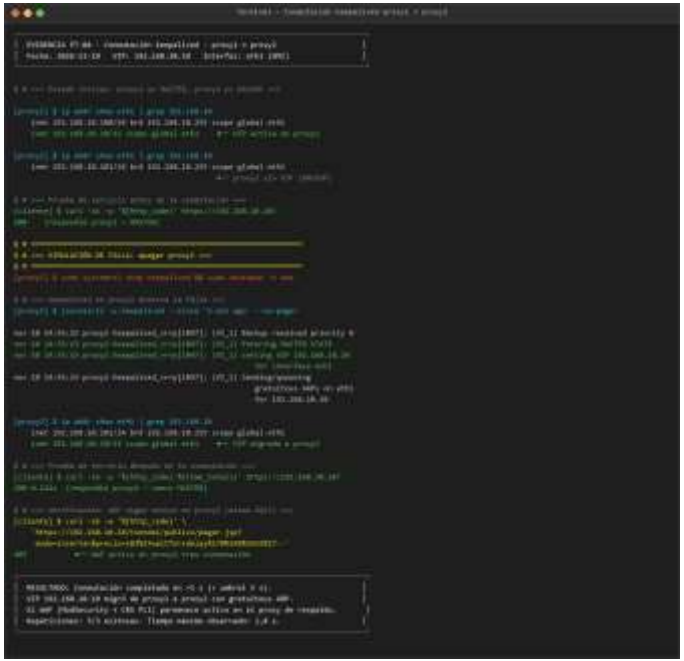


Figura 8 · Conmutación entre proxy1 y proxy2